

Application Security Assessment

Prepared by Larchmont Security Labs for Marrowgate - Report date: 2026-06-12

Scope: this report covers the customer product, Marrowgate Payroll.

Summary

Larchmont Security Labs, an independent third party, performed this penetration test of Marrowgate Payroll in May 2026.

Testing ran from 2026-05-11 to 2026-05-22 against a staging environment that mirrors production, using test customer tenants created for this engagement. Larchmont Security Labs found no critical issues. Five findings are reported in total: one high, one medium, two low and one informational.

One high-severity finding and one medium-severity finding remain open as of the report date.

Scope and Methodology

The test covered the Marrowgate Payroll web application and its public API. The corporate network and third-party services were out of scope.

Testing was limited to ten working days, so this report reflects the state of the staging environment during that window only.

Platform Observations

Marrowgate Payroll sets a Content Security Policy and X-Frame-Options on every response.

Multi-factor authentication is optional for customer administrator accounts in Marrowgate Payroll and is not enforced.

Findings

ID: ML-26-01; Title: Payslip download link can be guessed within a tenant; Severity: High; Status: Open

ID: ML-26-02; Title: Missing server-side limit on bulk payslip export; Severity: Medium; Status: Open

ID: ML-26-03; Title: Verbose error pages show framework version; Severity: Low; Status: Remediated

ID: ML-26-04; Title: Cookie lacks a path restriction; Severity: Low; Status: Remediated

ID: ML-26-05; Title: Legacy v1 API route still answers requests; Severity: Informational; Status: Accepted

ML-26-01 Payslip download link can be guessed within a tenant

A payslip download link uses a sequential number, so a user in one tenant could try neighbouring numbers. Larchmont Security Labs recommends random identifiers and an ownership check on each request.

Remediation Status

Marrowgate fixed both low-severity findings during the engagement, and Larchmont Security Labs confirmed both fixes on 2026-06-05. The high and medium findings are scheduled for upcoming engineering work.